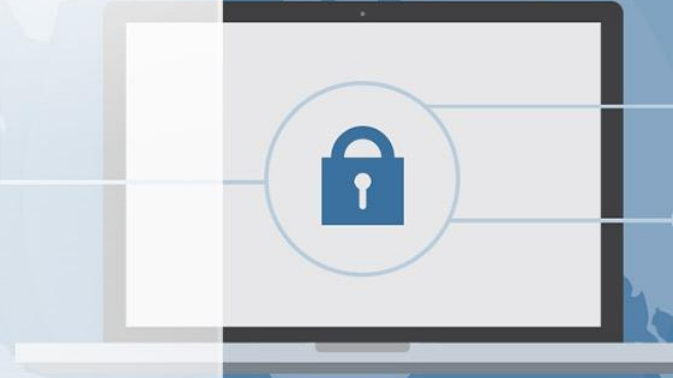




Information Security

Security Controls for CIA

- Now move from:
- **"What went wrong?"**
- to:
- **"How do we prevent it?"**



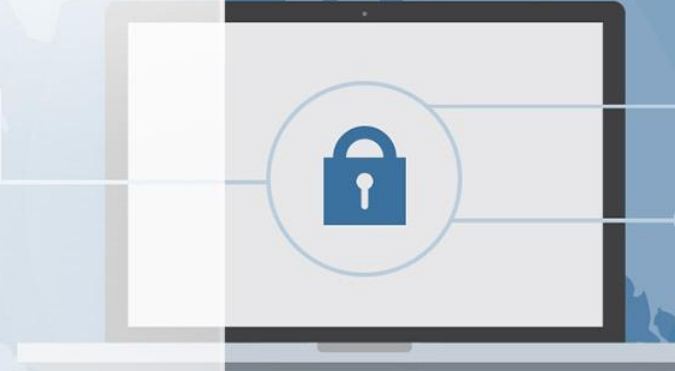
CIA Controls



Confidentiality Controls

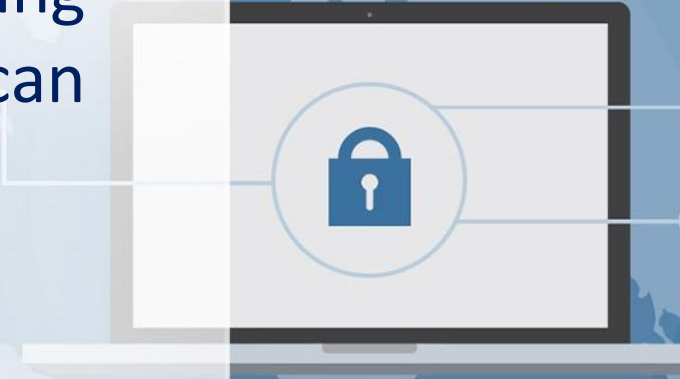
Examples:

- Encryption
- Access control
- Authentication
- Authorization
- VPN
- Data classification
- Least privilege
- Network segmentation



Question

- If someone steals a laptop containing sensitive data, what control can protect the data?



1. Encryption

Encryption is the process of converting readable information (**plaintext**) into an unreadable form (**ciphertext**) using an encryption algorithm and a key.

Plaintext → Encryption + Key → Ciphertext → Decryption + Key → Plaintext

Example

A student sends:

My password is ABC123

After encryption, it may look like:

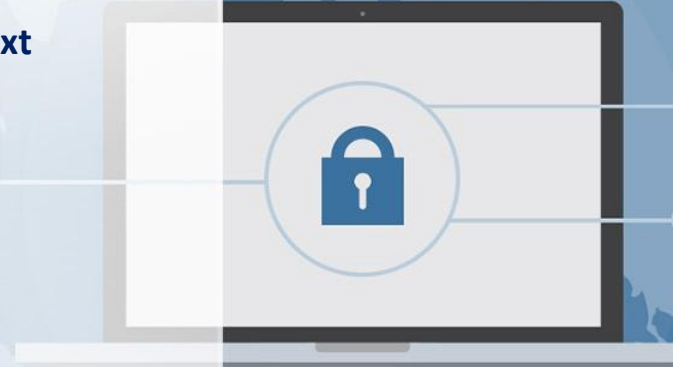
8fA7\$X92Kp...

Only an authorized person with the correct key can decrypt it.

Example

HTTPS encrypts communication between a browser and a website.

WhatsApp uses end-to-end encryption to protect messages.



Task

Scenario:

A university stores students' examination results on a server. An attacker steals the database.

- What happens if the database is not encrypted?
- How can encryption protect the stolen data?
- Should the university use symmetric or asymmetric encryption? Why?
- Identify where encryption should be applied.

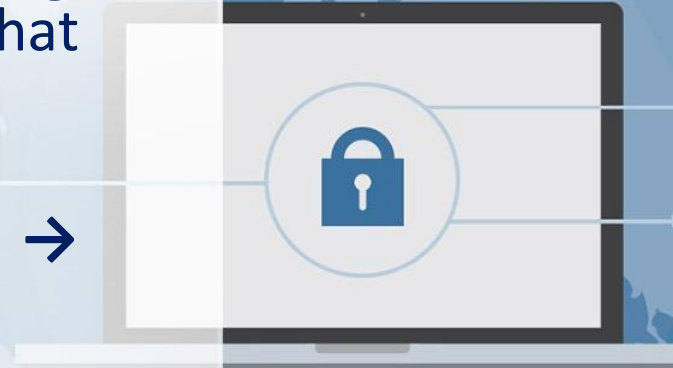


Access Control

Access control is the process of controlling who can access which resources and what actions they can perform.

User → Authentication → Access Control → Resource

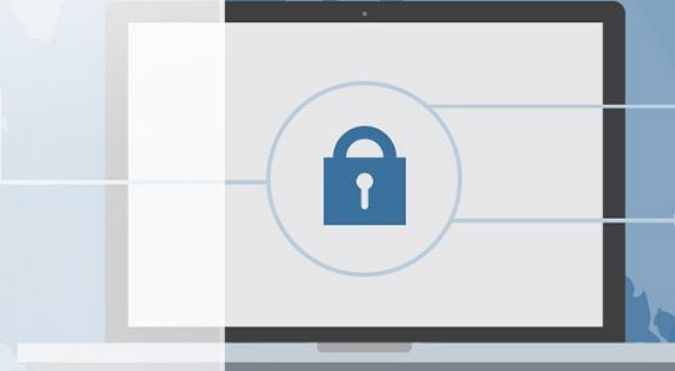
Example : A student can access their own academic record but cannot modify another student's result.



Task

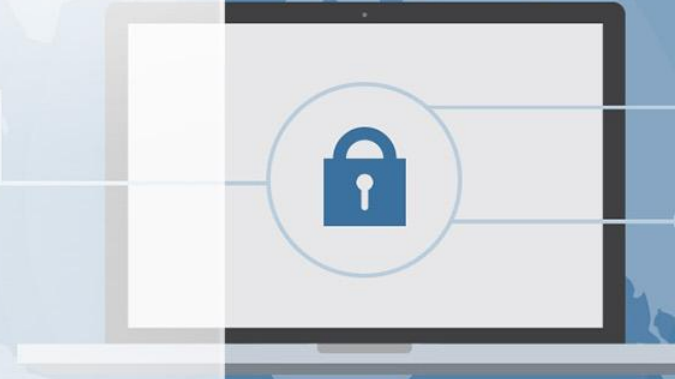
A university has a student management system containing:
Student records Teacher records Examination results
Fee information etc.

Design an access-control policy for:
Student
Teacher
Examination Officer
System Administrator
specify who can view, modify, and delete each type of data.



Question?

- What about RBAC, ABAC ?



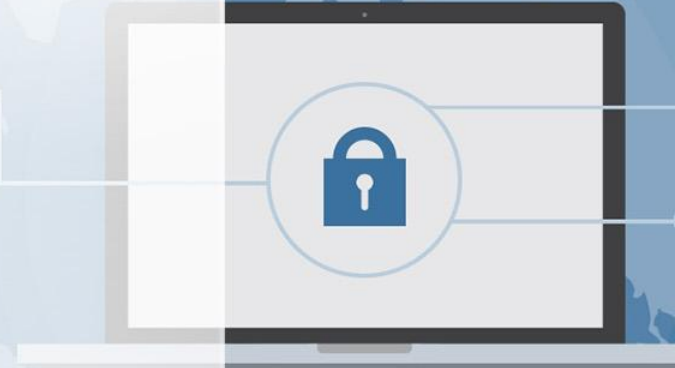
Authentication

Authentication is the process of verifying the identity of a user, device, or system.

Simply: "Who are you?"

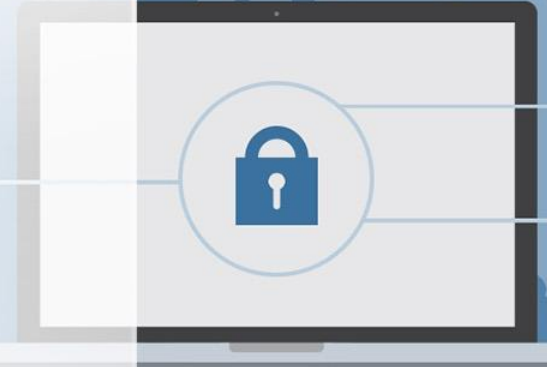
Common Authentication Methods:

- Something you know – Password/PIN
- Something you have – OTP/security token
- Something you are – Fingerprint/Face
- Somewhere you are – Location-based authentication



Example

- When a student logs into the university LMS using:
- Username + Password + OTP
- the system verifies that the person is really the account owner.

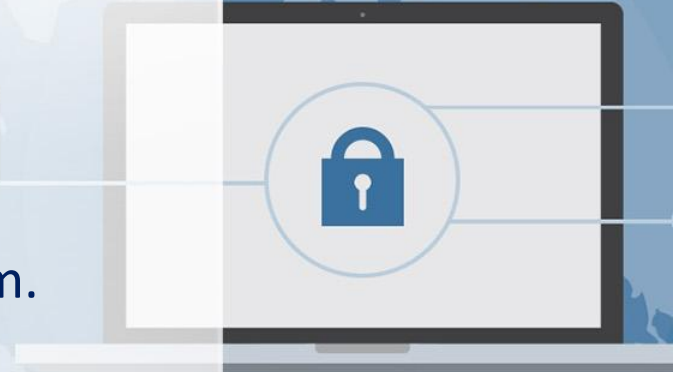


Scenario:

A university LMS currently uses only usernames and passwords. Several student accounts have been compromised.

Task:

- Identify the weakness.
- Propose a stronger authentication mechanism.
- Explain how MFA could reduce account compromise.
- Design a login process using two or three authentication factors.



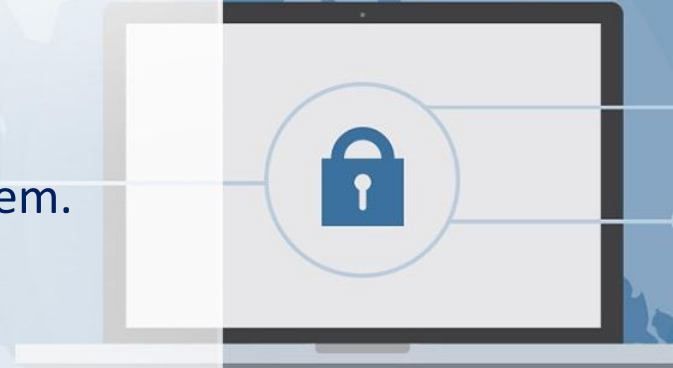
Authorization

Authorization determines **what an authenticated user is allowed to do** after their identity has been verified.

Simply "What are you allowed to do?"

Example

- A teacher successfully logs into the university system.
- **Authentication:**
This is Teacher A.
- **Authorization:**
Teacher A can view and update marks for assigned courses but cannot access payroll records.



Scenario:

A hospital employee logs into the hospital information system. The system contains:
Patient records, Doctor records, Billing ,
Pharmacy, HR information etc.

Determine what each user should be authorized to access:

Doctor Nurse Pharmacist Accountant HR Officer
IT Administrator.



VPN — Virtual Private Network

A **VPN** creates a secure, encrypted connection between a user's device and a private network or VPN server over an untrusted network such as the Internet.

Without VPN:

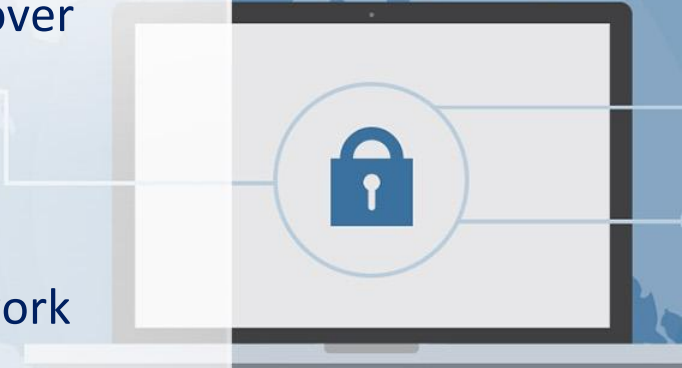
- User → Internet → University Server

With VPN:

- User → Encrypted VPN Tunnel → University Network
→ Server

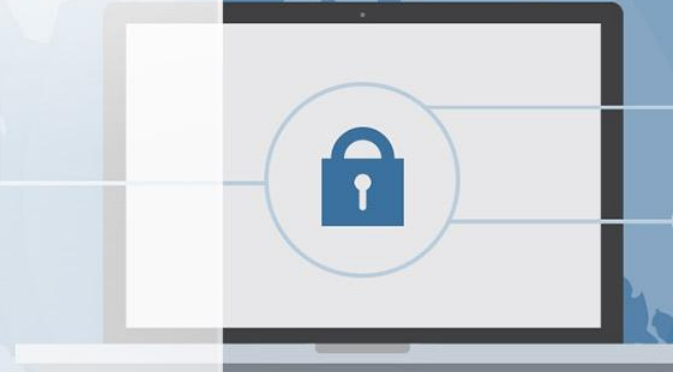
Example

- A university teacher working from home uses a VPN to securely access internal university systems.



Why VPN?

- Protects data over public networks
- Encrypts network traffic
- Provides secure remote access
- Helps protect against network interception

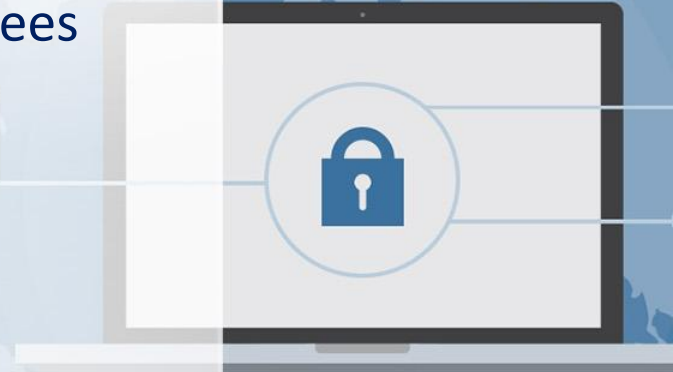


Casestudy:

University staff members work from home and need access to internal servers. Some employees use public Wi-Fi at cafés and airports.

Task:

- Identify the security risks.
- Explain how VPN can reduce these risks.
- Design a secure remote-access architecture.
- Should every employee automatically receive VPN access? Explain.

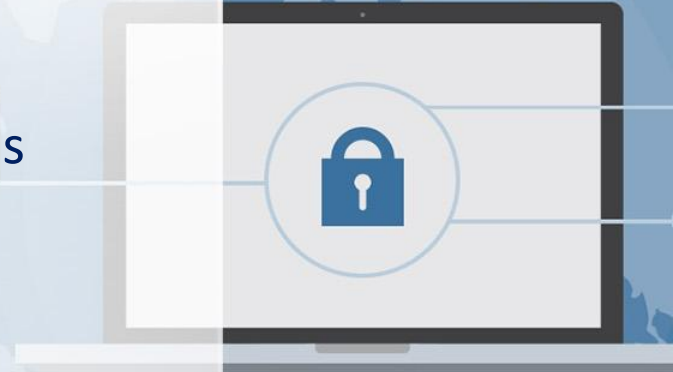


Data Classification

- **Data classification** is the process of categorizing information according to its sensitivity, importance, and security requirements.
- Higher sensitivity → Stronger security controls

For example:

- Public → Basic protection
- Confidential → Access control + Encryption
- Highly Confidential → Encryption + MFA + Strict access + Monitoring



Classification

Classification	Meaning	Example
Public	Can be shared publicly	University website
Internal	For organization use	Internal notices
Confidential	Restricted information	Student records
Highly Confidential	Extremely sensitive	Passwords, financial records



Least Privilege

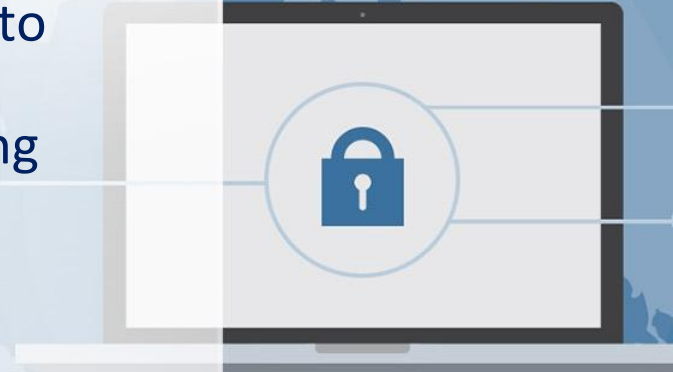
Least privilege means giving a user, application, or system only the minimum permissions required to perform its job.

- Give only the access that is necessary - nothing more.

Example:

A receptionist needs to view appointment information. They don't need:

- Database administrator privileges
- Patient record deletion
- Server configuration access



Task

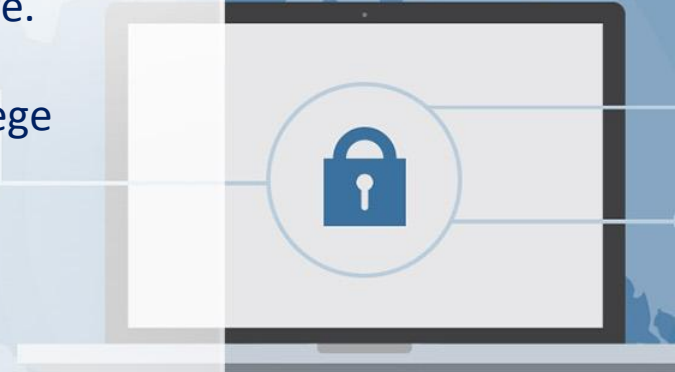
A university gives every employee administrator privileges on their computers. One employee accidentally installs malware.

Task: Identify the security problem. Explain how least privilege could reduce the impact.

Define appropriate privileges for:

- ☐ Student
- ☐ Teacher
- ☐ Lab Assistant
- ☐ IT Support
- ☐ System Administrator

Identify which privileges should be removed.

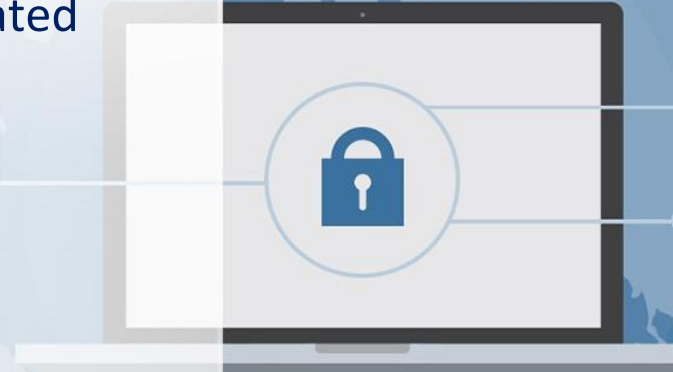


Network Segmentation

Network segmentation divides a network into separate sections so that users, devices, and services are isolated according to their security requirements.

Instead of:

- One Large Network → Everything Connected
- Use Small Network
 - Student Network
 - Faculty Network
 - Server Network
 - Guest Network
 - IoT Network
 - Management Network



Example

A university can separate:

Student Wi-Fi

Faculty Wi-Fi

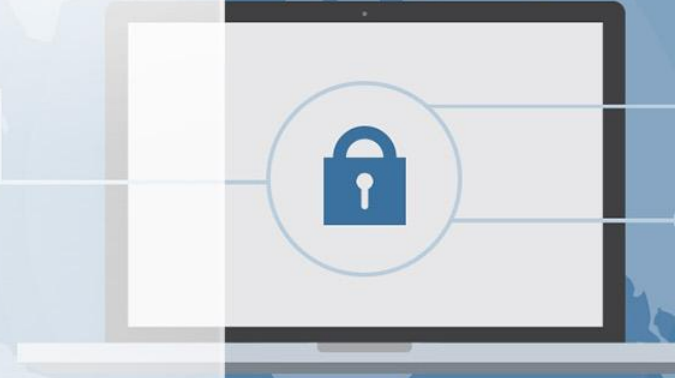
Administration

Servers

CCTV/IoT

Guest Wi-Fi

A student device should not be able to directly communicate with critical administrative servers.



Scenario:

A university has one large network containing:
Student laptops Faculty computers Servers CCTV
cameras Printers IoT devices Guest users. A
compromised student's laptop starts scanning other
systems.

Task:

Identify the security weaknesses.

Design a segmented network.

Decide which devices should communicate with each other.

Identify where firewalls should be placed.

